

Name : Tatenda Robin Kazonda

Email address : kazondarobin@gmail.com

AWS Security Assessment Report:

Client / Target : Personal AWS Account Baseline

Assessment Date : August 2026

Assessor : Cybersecurity Analyst

Scope : Default AWS Infrastructure and Account Configuration

Framework Baseline : AWS Well-Architected Framework (Security Pillar) , CIS AWS Foundations Benchmark v3.0.

Executive Summary:

A security assessment was performed on a standalone AWS account to evaluate baseline account security posture , identify controls and default network policies against cloud security standards.

Because this account currently has no active operational workloads deployed (zero EC2 compute instances , S3 storage buckets or RDS databases) no active data exposure vulnerabilities were present. However evaluating account-level defaults revealed critical baseline configuration gaps:

- **Storage Default** : Account-level default EBS volume encryption is disabled.
- **Default Network Hygiene** : The default VPC Security Group allows unrestricted internal ingress traffic.

Immediate implementation of foundational account guardrails is required before any production or test workloads are deployed.

Assessment Framework and Methodology

This assessment evaluated account settings against the AWS Well-Architected Framework (Security Pillar) and the Center for Internet Security (CIS) AWS Foundations Benchmark v3.0.

The evaluation analyzed baseline controls across four core domains:

1. **Identify and Access Management (IAM)** : Governance of `root` user credentials , MFA enforcement and access key rotation.

2. **Account-Level Storage and Encryption Defaults:** Configuration of S3 Block Public Access and regional EBS encryption settings.
3. **Default Network Perimeter Security :** Ingress/egress rules of default VPC Security Groups.
4. **Audit Logging Readiness:** Status of CloudTrail management events and AWS Trusted Advisor baseline security checks.

Summary of Findings

Finding ID	Evaluated Component	Category	Finding Summary	Severity
SEC-01	Account <code>root</code> User	Identity and Governance	Multi-Factor Authentication (MFA) is active on the <code>root</code> user.	Low/Info
SEC-02	Account EBS Settings	Data Protection	Account-level default EBS volume encryption is disabled.	Medium
SEC-03	Default VPC Security Group	Network Protection	Default Security Group allows unrestricted self-ingress (<code>ALL Traffic</code> from same SG).	Low
SEC-04	EC2 / RDS Instances	Infrastructure Scope	No active instances exist. Verified zero public IP exposure on management ports.	Info
SEC-05	S3 Storage Buckets	Data Protection Scope	No active S3 buckets exist . Verified account-level S3 Block Public Access status.	Info

Audit Evaluation and Risk Analysis

SEC-01 : Root Account Multi-Factor Authentication (MFA)

- **Component Evaluation :** IAM `root` User Credentials
- **Finding Details:** Audit of the IAM Credential Report confirmed that Multi-Factor Authentication (MFA) is enabled and active for the `root` account.

- **Risk Assessment** : Pass. Enforcing MFA on the `root` user satisfies a critical core control of the AWS Well-Architected Framework (Security Pillar) and CIS AWS Foundations Benchmark (Control 1.1). This effectively mitigates the risk of full account takeover via compromised password credentials.

SEC-02: Account-level Default EBS Volume Encryption Disabled

- **Component Evaluated** : EC2 Regional Data Protection Settings
- **Finding Details**: The regional EC2 setting “EBS Encryption by Default “ is set to *Disabled*.
- **Risk Analysis**: While no active EC2 instances or EBS volumes are currently running , launching an EC2 instance in the future without explicitly specifying encryption will create encrypted block storage . This risks compliance violations under data protection standards (such as PCI-DSS or GDPR).

SEC-03 :Permissive Default VPC Security Group Ingress Rules

- **Component Evaluated** : Default VPC(`vpc-default`) / Default Security Group (`sg-default`)
- **Finding Details**: The default Security Group generated by AWS allows all inbound traffic originating from resources assigned to that same security group.
- **Risk Analysis** : If future workloads are launched using the default security group without custom rule definitions , compromised instances can freely pivot and send unauthorized traffic to other instances in the same VPC.

SEC-04 and SEC-05: Non-Existent Active Resources (Audit Verification and What Was Evaluated)

Because no active EC2 instances , RDS databases or custom S3 buckets exist in this account:

- **What Was Evaluated** : The account inventory was cross-referenced via the EC2, RDS and S3 Management Consoles alongside AWS Trusted Advisor security checks.
- **Public Port and Subnet Exposure Check**: Confirmed zero instances exist with assigned public IPs or open inbound ports (SSH 22, RDP 3389 , SQL 3306/5432).
- **S3 Bucket Public Access Check** : Verified that no storage buckets exist and confirmed that “S3 Block Public Access “ is enabled at the global account level.

- **Why This Was Evaluated** : Verifying that no unintended resources exist ensures that orphan instances or abandoned storage buckets from prior tests are not actively incurring charges or posing unmonitored security threats.

Security Recommendations and Account Hardening Plan

Immediate Baseline Setup (24 Hours)

1. Enable Default EBS Encryption (Priority : High):

Go to EC2 > EC2 Dashboard > Account Attributes > EBS Encryption and switch “Always encrypt new EBS volumes” to Enabled.

Long-Term Operational Guardrails (Before Deploying Workloads)

- 1. Restructure Default Network Ingress** : Remove all default inbound rules from the default VPC Security Group and enforce a default-deny posture.
- 2. Enable Logging and Monitoring** : Enable an AWS CloudTrail trail to log API actions across all regions to an encrypted S3 bucket.
- 3. Automate Security Auditing**: Use AWS Trusted Advisor and enable AWS Security Hub to run continuous automated checks against foundational security best practices.